

ANNEX No. 1

DATA PROCESSING AGREEMENT (DPA)

to Website Development Agreement No. dated

This Data Processing Agreement (the "**DPA**") is entered into on **20.....**, between:

1. BOOKA LTD., Company ID (EIK) **208363525**, with registered office at: 10 General Kiselov Str., 9000 Varna, Bulgaria, represented by its Manager, hereinafter referred to as the "**Processor**",

and

2., Company ID / VAT No.:
....., with registered office at:,
represented by, in his/her capacity as, hereinafter referred to as the "**Controller**",

(jointly referred to as the "Parties"),

and forms an integral part of the main Agreement to which it is attached. It applies whenever the Processor processes personal data on behalf of the Controller.

1. DEFINITIONS

In this DPA the terms "**personal data**", "**processing**", "**controller**", "**processor**", "**data subject**", "**personal data breach**", "**supervisory authority**" have the meanings given to them in **Regulation (EU) 2016/679 (GDPR)**.

"Main Agreement" means the Website Development Agreement to which this DPA is annexed, together with all its annexes and amendments.

"Sub-processor" means any third party engaged by the Processor to carry out processing activities on behalf of the Controller.

2. SUBJECT AND DURATION

2.1. This DPA governs the processing of personal data carried out by the Processor on behalf of the Controller in the context of:

- development, maintenance and hosting of the Controller's website;
- operation of the online booking system;
- sending transactional messages (confirmations, reminders);
- related ancillary activities under the Main Agreement.

2.2. The DPA shall remain in force for the duration of the Main Agreement. Following termination of the Main Agreement, the Processor's obligations regarding return/deletion of data and confidentiality shall

continue as set out in Sections 10 and 12 below.

3. NATURE, PURPOSE AND TYPE OF PROCESSING

3.1. Nature of processing: automated processing through information systems, including collection, storage, organisation, retrieval, use, transmission (to sub-processors), restriction and deletion of personal data.

3.2. Purposes of processing:

- receiving, processing and storing bookings;
- sending confirmations and reminder messages to data subjects;
- ensuring availability, security and maintenance of the website;
- assisting the Controller in fulfilling its legal obligations and responding to data subject rights requests.

3.3. Types of personal data: as configured under the Main Agreement:

- identification data (first name, last name);
- contact data (email, phone);
- booking data (date, time, service, notes entered by the data subject);
- technical data (IP address, browser, device, cookies);
- payment data (processed directly by Stripe — see Section 6.3);
- (other, if applicable).

3.4. Categories of data subjects:

- end customers of the Controller making bookings through the website;
- visitors to the website;
- employees or other persons authorised by the Controller for administrative access.

3.5. Upon initial setup, the Controller may expand or restrict the above categories in writing.

3.6. Special categories of personal data: the Processor does not knowingly process special categories of personal data under Art. 9 GDPR (including health data). If the Controller's business (e.g. medical, cosmetic or fitness centre) implies processing of such data through the website, the Controller shall be responsible for the relevant legal basis and shall inform the Processor in writing so that additional technical and organisational measures can be put in place.

4. INSTRUCTIONS OF THE CONTROLLER

4.1. The Processor shall process personal data **only** on documented instructions from the Controller. This DPA, the Main Agreement and its annexes constitute complete documented instructions at the time of signing. Additional instructions shall be given in writing (including by email).

4.2. The Processor shall promptly inform the Controller if it considers that an instruction infringes the GDPR or other applicable data protection law.

4.3. Where the Processor is required by EU or Bulgarian law to process beyond the Controller's instructions, it shall inform the Controller of that legal requirement before processing, unless the law prohibits such information on important grounds of public interest.

5. OBLIGATIONS OF THE PROCESSOR

The Processor undertakes:

5.1. to process personal data only for the purposes in Section 3 and in accordance with the instructions in Section 4;

5.2. to ensure confidentiality, by binding its personnel with appropriate confidentiality undertakings and providing data protection awareness training;

5.3. to implement appropriate technical and organisational security measures as set out in Section 7;

5.4. to assist the Controller (insofar as possible and within reasonable means) in fulfilling its obligations under Articles 32–36 GDPR and in responding to data subject rights requests (Section 8);

5.5. to maintain a record of processing activities carried out on behalf of the Controller in accordance with Art. 30(2) GDPR;

5.6. to make available to the Controller all information necessary to demonstrate compliance with Art. 28 GDPR, and to allow for audits as set out in Section 11;

5.7. to return or delete the data upon request as set out in Section 12.

6. SUB-PROCESSORS

6.1. The Controller grants the Processor general prior authorisation to engage sub-processors for the performance of its obligations under the Main Agreement.

6.2. As of the date of this DPA, the Processor uses the following sub-processors:

Sub-processor	Activity	Location / safeguards
Vercel Inc.	Website hosting and edge delivery	USA / global edge — Standard Contractual Clauses (SCCs) + DPA
Stripe Payments Europe Ltd.	Payment processing	Ireland (EU) — independent controller for payment data
Resend, Inc.	Transactional email delivery	USA — SCCs + DPA
Google Ireland Ltd. (Google Analytics 4)	Web analytics (subject to visitor consent)	EU / USA — SCCs + EU-US Data Privacy Framework

6.3. Stripe acts as an **independent controller** with respect to data it collects in its capacity as a payment institution (payment instruction, card identification, AML/KYC). Such processing is not subject to this DPA.

6.4. Should the Processor intend to add or replace a sub-processor, it shall notify the Controller in advance (by email or by updating the list on its own website) and shall allow at least **14 (fourteen) calendar days** for written objection. In the case of a reasoned objection the Parties shall negotiate in good faith for an alternative solution. If no such solution can be found, the Controller may terminate the affected portion of the services.

6.5. The Processor shall impose on each sub-processor contractual data protection obligations no less protective than those set out in this DPA, and shall remain liable for the acts of its sub-processors as for its own.

7. SECURITY MEASURES

7.1. The Processor implements appropriate technical and organisational measures pursuant to Art. 32 GDPR, including:

- encryption in transit (TLS) and encryption of data at rest where technically feasible;
- storage of passwords with hashing and salting;
- access control on the principle of least privilege;
- regular access reviews and disabling of inactive accounts;
- vulnerability scanning and timely patching of software dependencies;
- audit logs for administrative actions;
- protection against brute-force attacks (rate limiting);
- secure development procedures (separate environments, code review);
- documented incident response procedures;
- periodic backups;
- vendor due diligence and signed DPAs with sub-processors.

7.2. Such measures are subject to periodic review and may be updated in line with technological developments and the scope of processing. Updates shall not lower the level of protection.

8. ASSISTANCE WITH DATA SUBJECT RIGHTS AND CONTROLLER OBLIGATIONS

8.1. The Processor shall assist the Controller (with appropriate technical and organisational measures, insofar as possible) in responding to data subject requests relating to:

- right of access (Art. 15);
- right to rectification (Art. 16);
- right to erasure / "to be forgotten" (Art. 17);
- right to restriction (Art. 18);
- right to data portability (Art. 20);
- right to object (Art. 21);
- rights related to automated individual decision-making (Art. 22).

8.2. If the Processor receives a request directly from a data subject, it shall not respond on the merits but shall forward the request to the Controller within 5 business days.

8.3. The Processor shall provide reasonable assistance to the Controller in fulfilling its obligations under Articles 32–36 GDPR (security, breach notification, data protection impact assessment and prior consultation).

8.4. Assistance under this Section is provided free of charge in the usual scope; for systematic, repeated or manifestly excessive requests the Processor may charge a reasonable fee.

9. PERSONAL DATA BREACH

9.1. Upon becoming aware of a personal data breach affecting data processed on behalf of the Controller, the Processor shall notify the Controller **without undue delay** and no later than **72 (seventy-two) hours** from awareness, by email to the Controller's contact address.

9.2. The notification shall include at least:

- description of the nature of the breach;
- categories and approximate number of affected data subjects and records;
- likely consequences;
- measures taken or proposed to address the breach and mitigate its adverse effects;
- contact details for further information.

9.3. Where the full information cannot be provided at once, it shall be provided in phases without undue delay.

10. INTERNATIONAL DATA TRANSFERS

10.1. To the extent processing by sub-processors (Section 6) involves transfers of personal data outside the EEA, the Processor shall ensure that at least one of the following safeguards under Chapter V GDPR is in place:

- adequacy decision of the European Commission (including the EU-US Data Privacy Framework);
- Standard Contractual Clauses (Commission Implementing Decision (EU) 2021/914);
- other appropriate safeguards provided for under GDPR.

10.2. Copies of the applicable safeguards shall be made available to the Controller upon written request.

11. AUDITS AND INSPECTIONS

11.1. The Controller may request from the Processor the information and documents necessary to demonstrate compliance with this DPA, once per year, or more frequently if there is a specific cause for concern (e.g. following an incident).

11.2. If an on-site audit is requested, the Parties shall agree on a reasonable timeframe (not shorter than 30 days), scope and conditions. The audit shall be conducted during business hours, without unreasonable disruption to the Processor's operations, and subject to a signed confidentiality undertaking.

11.3. The audit costs shall be borne by the Controller. If the audit identifies material non-compliance by the Processor, the Processor shall bear the cost of any follow-up audit verifying remediation.

11.4. Where sufficient, requests for information may be fulfilled by providing the Processor's or its sub-processors' current reports or certifications.

12. RETURN AND DELETION OF DATA

12.1. Upon termination of the Main Agreement, at the Controller's option, the Processor shall:

- return all personal data in a structured, commonly used, machine-readable format; and/or
- delete all existing copies,

within **60 (sixty) calendar days** of termination, unless EU or Bulgarian law requires longer retention.

12.2. Backup copies shall be deleted automatically within the regular overwrite cycle (up to 30 days).

12.3. Upon request, the Processor shall provide written confirmation of deletion.

13. LIABILITY

13.1. Liability of the Processor under this DPA is governed jointly with and subject to the liability limitations set out in the Main Agreement.

13.2. Nothing in this DPA shall limit liabilities that cannot be limited under applicable law, including liability to data subjects and to the supervisory authority under Art. 82 GDPR.

14. GOVERNING LAW AND DISPUTES

14.1. This DPA shall be governed by the laws of Bulgaria.

14.2. Disputes shall be resolved through negotiation; failing agreement, by the competent Bulgarian court at the registered seat of the Processor.

15. FINAL PROVISIONS

15.1. In case of conflict between this DPA and the Main Agreement on data protection matters, this DPA shall prevail.

15.2. Amendments and additions may only be made in writing by a signed addendum.

15.3. This DPA is executed in **2 (two)** identical counterparts — one for each Party.

FOR THE PROCESSOR:	FOR THE CONTROLLER:
BOOKA LTD., Company ID 208363525	
_____	_____
.....	
Manager	Title:
Date:	Date: